

Security Controls in Shared Source Code Repositories

Keanu Foltz
CSD 380





Source Code Repositories and Security

- Shared repositories can include sensitive data
- Unsecured repositories run the risks of code tampering, theft of IP, and credential leaks
- With software supply chain attacks on the rise we must keep our repositories secure





Source Code Protection Policy

- Rules, requirements, and procedures should be set for handling and protecting source code
- This includes the standards regarding how repositories are accessed and used
- Documentation and training on source code protection policies should be given to applicable team members





Access Controls

- Always use least privilege for access controls to prevent unauthorized changes and leaks
- Granular access controls prevent over exposure of repositories and accidental leaks
- Audit user permissions regularly
- 2 factor or multi factor authentication should be used as an extra layer of security
- Commits should require token based authentication or SSH keys





Encryption and Monitoring

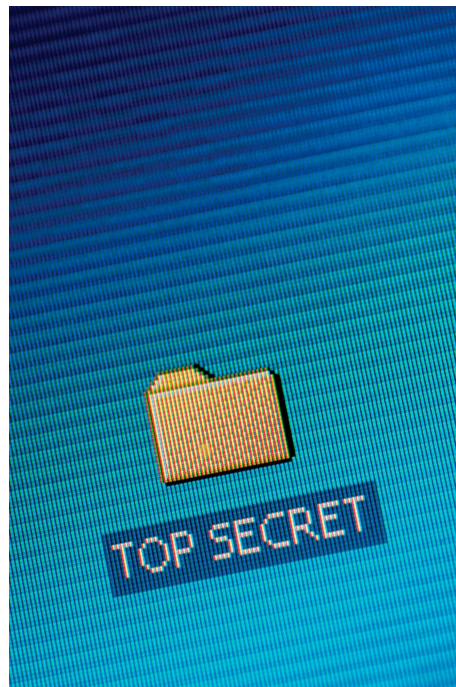
- Using encryption tools adds another layer of source code security
- When using cloud hosted repositories, data in transit should be encrypted with SSL/TLS and stored with AES 256 bit encryption
- Logging and monitoring of remote access attempts will help with discovering threats before damage is done





Secret/Credential Management

- Credentials and other secrets should not be directly committed to the repository
- Use tools such as Vault, sneaker, Keywhiz, credstash, Trousseau for secret management





References

- <https://get.assembla.com/blog/source-code-security/>
- <https://www.endpointprotector.com/blog/your-ultimate-guide-to-source-code-protection/>